

راهنمای کامل احراز هویت فرانت React

قرارداد API ورود، تمدید نشست، کپچای تطبیقی و کنترل‌های امنیتی مخصوص
کلاينت وب

عامل احراز هویت

JWT و نشست سمت سرور

نوع نشست

WEB

کلاينت‌ها

localhost و dlander.com

محافظت ورود

Rate limit و CAPTCHA تطبیقی

۱. ورود معمولی

فرانت React درخواست زیر را ارسال می‌کند:

```
POST /api/v1/auth/login
Content-Type: application/json

{
  "email": "user@example.com",
  "password": "StrongPass123"
}
```

پاسخ موفق در قالب استاندارد API:

```
{
  "data": {
    "accessToken": "ACCESS_TOKEN",
    "refreshToken": "REFRESH_TOKEN",
    "user": {
      "id": "user-uuid",
      "email": "user@example.com",
      "displayName": "User",
      "role": "USER",
      "status": "ACTIVE"
    }
  },
  "meta": null
}
```

اگر `AUTH_REFRESH_TOKEN_TRANSPORT=cookie` باشد، refresh token داخل Cookie امن و HttpOnly قرار می‌گیرد و در JSON بازگردانده نمی‌شود.

۲. استفاده از Access Token

برای تمام endpointهای محافظت‌شده، access token در هدر ارسال می‌شود:

```
GET /api/v1/users/me
Authorization: Bearer ACCESS_TOKEN
```

React به هدرهای `X-Dlander-Installation-Key` و `X-Dlander-Site-Url` نیاز ندارد؛ این هدرها مخصوص نشست WordPress هستند.

۲. تمدید توکن

حالت انتقال در بدنه

```
POST /api/v1/auth/refresh
Content-Type: application/json

{ "refreshToken": "REFRESH_TOKEN" }
```

حالت Cookie

```
POST /api/v1/auth/refresh
credentials: include
```

پس از تمدید، access token و refresh token جدید صادر می‌شوند و refresh token قبلی دیگر معتبر نیست.

۴. خروج

```
POST /api/v1/auth/logout
Authorization: Bearer ACCESS_TOKEN
```

برای خروج از تمام دستگاه‌ها:

```
POST /api/v1/auth/logout-all
Authorization: Bearer ACCESS_TOKEN
```

۵. کپچای تطبیقی در React

در اولین ورود ناموفق:

```
{
  "error": {
    "statusCode": 401,
    "message": "Invalid email or password",
    "code": "INVALID_LOGIN",
    "captchaRequired": false
  },
  "meta": null
}
```

با تنظیم پیش‌فرض، بعد از دومین ورود ناموفق:

```
{
  "error": {
    "statusCode": 401,
    "message": "Invalid email or password",
    "code": "CAPTCHA_REQUIRED",
    "captchaRequired": true
  },
  "meta": null
}
```

فرانت باید با مشاهده `error.code === 'CAPTCHA_REQUIRED'` فرم کپچا را نمایش دهد.

دریافت تصویر کپچا

```
POST /api/v1/auth/captcha
Content-Type: application/json

{ "email": "user@example.com" }
```

```
{
  "data": {
    "captchaId": "captcha-uuid",
    "image": "data:image/svg+xml;base64,...",
    "expiresAt": "2026-08-04T20:00:00.000Z"
  },
  "meta": null
}
```

تصویر با `<img src={captcha.image} alt="Captcha" />` قابل نمایش است.

```
POST /api/v1/auth/login
Content-Type: application/json

{
  "email": "user@example.com",
  "password": "StrongPass123",
  "captchaId": "captcha-uuid",
  "captchaCode": "7K9P2"
}
```

اگر کپچا اشتباه، مصرف‌شده یا منقضی باشد، خطای `INVALID_CAPTCHA` برمی‌گردد و فرانت باید چالش جدیدی دریافت کند.

الگوی پیاده‌سازی React

```
async function login(payload) {
  const response = await fetch('/api/v1/auth/login', {
    method: 'POST',
    headers: { 'Content-Type': 'application/json' },
    credentials: 'include',
    body: JSON.stringify(payload),
  });
  const result = await response.json();

  if (['CAPTCHA_REQUIRED', 'INVALID_CAPTCHA'].includes(result.error?.code)) {
    const captchaResponse = await fetch('/api/v1/auth/captcha', {
      method: 'POST',
      headers: { 'Content-Type': 'application/json' },
      body: JSON.stringify({ email: payload.email }),
    });
    const captchaResult = await captchaResponse.json();
    return { captchaRequired: true, captcha: captchaResult.data, error: result.error };
  }
  if (!response.ok) throw result.error;
  return result.data;
}
```

۶. امنیت اعمال شده برای React

مدل امنیتی: JWT کوتاه عمر + نشست قابل ابطال در دیتابیس + refresh rotation + کپچای تطبیقی + rate limiting.

نشست سمت سرور

JWT فقط از نظر امضا بررسی نمی‌شود. هر توکن دارای sessionId است و سرور نشست را در دیتابیس کنترل می‌کند. نشست در صورت ابطال، انقضا، مسدود یا حذف شدن کاربر، logout-all یا تغییر رمز قابل رد شدن است.

Refresh Token Rotation

- در هر refresh توکن جدید صادر و توکن قبلی نامعتبر می‌شود.
- استفاده دوباره از توکن قبلی به عنوان reuse تشخیص داده می‌شود.
- در صورت reuse، نشست باطل می‌شود.
- هش refresh token با Argon2 در دیتابیس نگهداری می‌شود.

کپچای تطبیقی

- محدودیت بر اساس ترکیب ایمیل normalize شده و IP است.
- پس از ۲ تلاش ناموفق فعال می‌شود، ۵ دقیقه اعتبار دارد و یک بار مصرف است.
- پس از ۵ پاسخ اشتباه پذیرفته نمی‌شود.
- کپچای صحیح پیش از بررسی نهایی رمز مصرف می‌شود تا نتوان با یک پاسخ چند رمز را امتحان کرد.
- با ورود موفق شمارنده خطا پاک می‌شود.

```
CAPTCHA_FAILURE_THRESHOLD=2
CAPTCHA_TTL_SECONDS=300
CAPTCHA_MAX_ATTEMPTS=5
```

Rate Limit و CORS

```
FRONTEND_URL=https://d1ander.com
CORS_ORIGINS=http://localhost:5173,https://d1ander.com
```

CORS فقط دسترسی مرورگر را کنترل می‌کند و جایگزین authentication نیست. endpoint های ورود، کپچا، refresh و بازیابی رمز نیز rate limit دارند.